

Analyse TPRM

Third-Party Risk Management

Snort

pfSense

KeePass

Adam JLAIEL · Abdelkrim MESSAOUDENE · Sajid MARZOUKY

Encadré par M. HEDDA · M. OUELAALI · Mme AMZAL | Année 2025-2026

BUT R&T 2e année — Cybersécurité — Groupe 1

Plan de la présentation

01

Contexte & objectifs

Qu'est-ce que le TPRM et pourquoi ces trois outils ?

02

Rôle des outils

Snort, pfSense, KeePass — ce qu'on a fait en TP

03

Analyse des risques

Identification par outil, ancrée sur les TPs & Root-Me

04

Matrice de priorisation

Impact × Probabilité — les 7 risques critiques

05

Mesures & recommandations

Mesures concrètes + intégration contractuelle TPRM

06

Synthèse

Acceptation sous conditions — ce qu'on exigerait en vrai

01 — Contexte & objectifs

"Qu'est-ce qui peut mal tourner si c'est un prestataire qui gère nos outils de sécurité ?"

TPRM c'est quoi ?

Third-Party Risk Management = analyser et encadrer les risques liés aux prestataires externes qui gèrent des outils critiques pour nous.

Notre scénario

Une entreprise confie Snort, pfSense et KeePass à un partenaire externe. On se place côté client : que risque-t-on ?

Nos sources

TPs réalisés (pfSense + KeePass + Root-Me G1), CR Snort transmis par G2, challenges Root-Me (SSH, FTP, injection de commande...).

02 — Rôle des outils dans le contexte TPRM

Snort

NIDS (Network IDS)

CE QU'ON A FAIT EN TP

G2 : installation sur Kali, 4 règles locales (TCP keywords, ICMP ping, SSH SYN), test avec Scapy — 3 paquets détectés en temps réel.

ENJEU TPRM

C'est le prestataire qui choisit les règles, le placement et qui reçoit les logs → le client est aveugle sans accès direct.

pfSense

Pare-feu / Routeur / VPN / IPS

CE QU'ON A FAIT EN TP

G1 : VM VirtualBox, alias IP malveillantes, règles HTTP/HTTPS, OpenVPN SSL+User Auth, Suricata ET Open, pfBlockerNG (Abuse Feodo, CINS army...)

ENJEU TPRM

Single point of failure du réseau. Toute mauvaise config du prestataire a un impact immédiat et total sur l'infrastructure.

KeePass

Gestionnaire de mots de passe

CE QU'ON A FAIT EN TP

G1 : base .kdbx créée, mots de passe générés à 146-150 bits (YouTube, Gmail, ENT, comptes pfSense admin + tonton-distant).

ENJEU TPRM

Concentre TOUS les secrets d'administration. Si le fichier fuit, tout tombe — c'est le point de compromission unique.

03 Analyse des risques

Ce qu'on a observé pendant les TPs et les challenges Root-Me

Snort — Risques identifiés

NIDS — Détection d'intrusion réseau

Règles obsolètes / non mises à jour

Dans le TP du G2 : 4 règles pédagogiques ("attaque", "vulnérabilité", ICMP, SSH). En prod les règles Talos/ET doivent être mises à jour quotidiennement.

Critique

Placement inadapté — angle mort LAN

Si une seule sonde en DMZ, le trafic interne n'est pas surveillé. Or statistiquement ~80% des incidents viennent de l'intérieur.

Élevé

Logs non centralisés / accessibles

Par défaut les alertes sont dans /var/log/snort/ sur la machine. Sans SIEM partagé, le client ne peut pas vérifier ce que le prestataire a détecté.

Élevé

Faux positifs mal gérés

Des règles trop larges noient les vraies alertes. Sans tuning régulier, l'équipe finit par ignorer toutes les alertes — y compris les vraies.

Modéré

pfSense — Risques identifiés

Pare-feu / Routeur / VPN / IPS — Single point of failure du réseau

Compte admin par défaut non changé

Pendant tout notre TP : bandeau rouge "admin/pfsense encore par défaut". En production c'est la porte ouverte. Première chose à faire à la mise en service.

Critique

VPN sans MFA

Notre OpenVPN est en SSL+User Auth mais sans double authentification. Si les identifiants de tonton-distant fuient (phishing, KeePass compromis), le tunnel est ouvert.

Critique

Règles pare-feu trop permissives

Vu en TP : "any" vers le serveur web interne. Combiné à une appli vulnérable → injection de commande Root-Me : cmd=pwd, cmd=id, wget depuis serveur externe.

Critique

Absence de sauvegarde config

pfSense exporte en XML mais rien n'oblige le prestataire à le faire. Reconstruire VPN, Suricata, pfBlockerNG, certificats : énorme. Perte totale possible.

Élevé

KeePass — Risques identifiés

Gestionnaire de mots de passe — Concentre TOUS les secrets d'administration

Mot de passe maître trop faible

Premier essai en TP : 31 bits estimés par KeePass — cassable avec un bon GPU sur un .kdbx exfiltré. Sans politique stricte le prestataire peut faire la même chose.

Critique

Fichier .kdbx exfiltré / mal protégé

Challenge Root-Me Bash/Clés SSH : clé privée dans un dossier backup → accès SSH + escalade privilèges. Même raisonnement : un .kdbx qui traîne = tout compromis.

Critique

Partage informel de secrets

KeePass ne gère pas nativement le multi-utilisateur avec droits différenciés. Partage par email ou partage réseau non sécurisé = risque de fuite silencieuse.

Critique

Aucune journalisation des consultations

KeePass 2 ne logue pas qui consulte quelle entrée. En cas d'incident ou de suspicion de fuite, impossible de tracer les accès après coup.

Élevé

04 — Matrice Impact × Probabilité

15 risques identifiés — 7 classés Critiques

	Impact Faible	Impact Moyen	Impact Fort
Prob. Élevée	Modéré Faux positifs Snort	Élevé Placement Snort, Certif. auto-signé	Critique Règles Snort obsolètes, VPN sans MFA, Compte admin défaut, MdP maître faible, .kdbx exfiltré
Prob. Modérée	Faible —	Modéré Logs non centralisés, Absence sauveg.	Élevé Partage KeePass informel, Exposition WAN
Prob. Faible	Faible —	Faible —	Modéré Journalisation KeePass absente

05 — Mesures de réduction du risque

SNORT

Règles à jour quotidiennement

Cron de mise à jour ET Open / Talos
→ Rapport mensuel de preuve au client

2 sondes minimum

Une en DMZ + une sur le LAN interne
→ Documenté dans l'architecture

SIEM partagé

Logs envoyés vers ELK/Graylog côté client
→ Accès lecture garanti par contrat

SLA alertes critiques

Prise en charge < 30 min sur critique
→ Clause contractuelle obligatoire

PFSense

Changer les identifiants dès l'install

Politique ≥ 16 chars, rotation annuelle
→ Vérifié à la mise en service par audit

MFA sur OpenVPN obligatoire

TOTP via package pfSense ou RADIUS
→ Sans MFA : accès VPN refusé contractuellement

Règles pare-feu en whitelist

Jamais "any" vers serveur appli
→ WAF en amont recommandé (cf. Root-Me)

Sauvegarde XML + test restauration

Export automatique quotidien hors du firewall
→ Test restauration 2x/an documenté

05 — Mesures de réduction du risque (suite)

KEEPASS

Mot de passe maître ≥ 128 bits

Générateur natif KeePass (on a atteint 146-150 bits en TP → faisable facilement)

Ajouter un fichier-clé séparé

Stocké séparément du .kdbx → les deux nécessaires pour ouvrir la base

Cloisonner par usage

Base pfSense ≠ base applis ≠ base perso → si une fuit, les autres restent protégées

Rotation au départ d'un collaborateur

Changement immédiat de tous les mots de passe auxquels il avait accès → délai max 24h contractuel

MESURES TRANSVERSES

Plan d'Assurance Sécurité (PAS)

Annexe contractuelle décrivant toutes les procédures du prestataire pour les 3 outils

Clause d'audit annuel

Droit d'audit sans préavis pour le client ou un tiers mandaté

Notification d'incident < 24h

En cas de suspicion de compromission → alerte immédiate côté client

Plan de réversibilité

En fin de contrat : remise des règles Snort, config pfSense, secrets KeePass

06 — Synthèse TPRM

Verdict :

OUI, ces outils peuvent être confiés à un prestataire — mais seulement si c'est très encadré.

Conditions techniques

- MFA obligatoire admin + VPN
- Identifiants par défaut changés
- Règles Snort à jour quotid.
- Logs SIEM côté client
- Sauvegardes testées 2x/an
- MdP maître KeePass ≥ 128 bits + fichier-clé

Conditions contractuelles

- Plan d'Assurance Sécurité (PAS)
- Audit annuel sans préavis
- Notification incident < 24 h
- SLA alerte critique < 30 min
- Plan de réversibilité formalisé

Conditions de gouvernance

- Revue sécu trimestrielle conjointe
- Tableau de bord mensuel incidents
- Rotation secrets à chaque départ RH
- Interdiction partage par canal non chiffré

Le problème n'est jamais dans les outils eux-mêmes — c'est toujours la configuration et la gouvernance.

Merci de votre attention

Questions ?

3

Outils analysés

15

Risques identifiés

7

Risques critiques

20+

Mesures proposées

Adam JLAIEL · Abdelkrim MESSAOUDENE · Sajid MARZOUKY

BUT R&T Cybersécurité — IUT Villetaneuse — SAE S401 — 2025-2026